

Основы информационной безопасности

Урок 6. Анализ и оценка защищенности



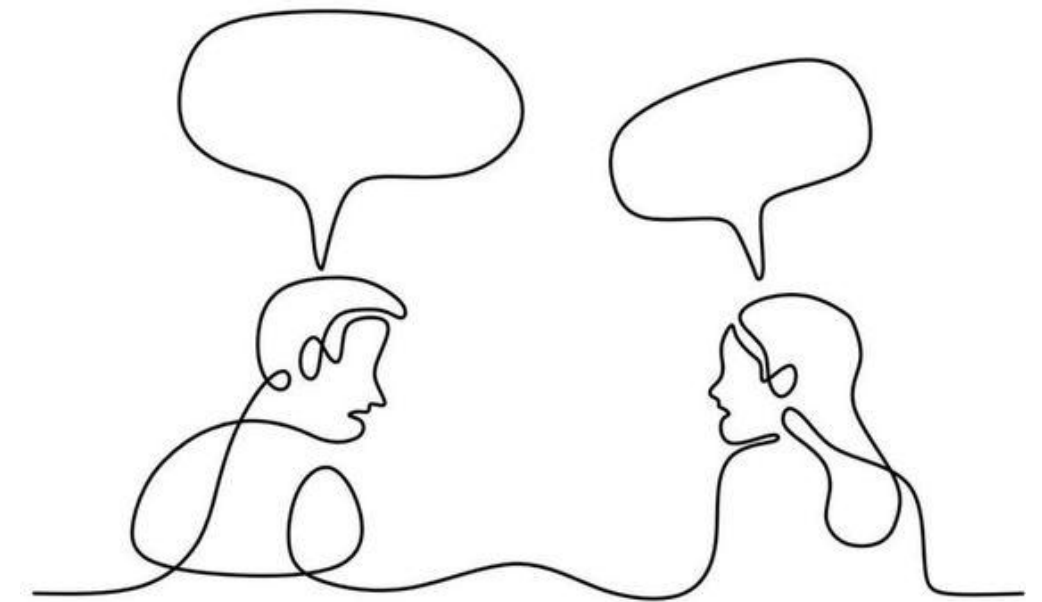
План курса





Что будет на уроке сегодня

- 📌 Цели и критерии оценки защищенности.
- 📌 Варианты оценки и анализ защищенности.
- 📌 Виды аудита информационной безопасности.
- 📌 Разведка по открытым источникам (OSINT).
- 📌 Тестирование на проникновение (pentest) и киберучения (cyber exercise).
- 📌 Методы анализа защищенности отдельных приложений.





Ключевые понятия

-  **Оценка соответствия информационной безопасности организации установленным требованиям:**
деятельность, связанная с прямым или косвенным определением выполнения или невыполнения в организации установленных требований информационной безопасности.
-  **Аттестация объекта информатизации:** комплекс организационных и технических мероприятий и работ (аттестационных испытаний), в результате которых подтверждается соответствие объекта информатизации требованиям по защите информации в условиях его эксплуатации.
-  **Технический контроль эффективности защиты информации (контроль защищенности системы):**
контроль эффективности защиты информации (защищенности системы), проводимый с использованием средств контроля, включающий тестирование на проникновение и/или анализ уязвимостей.



Ключевые понятия

-  **Аудит информационной безопасности организации:** систематический, независимый и документированный процесс получения свидетельств деятельности организации по обеспечению информационной безопасности и установлению степени выполнения в организации критериев информационной безопасности, а также допускающий возможность формирования профессионального аудиторского суждения о состоянии информационной безопасности организации.
-  **Свидетельство (доказательство) аудита информационной безопасности организации:** запись, изложение фактов или другая информация, которые имеют отношение к критериям аудита информационной безопасности организации и могут быть проверены.
-  **Критерий аудита информационной безопасности организации:** совокупность принципов, положений, требований и показателей действующих нормативных документов, относящихся к деятельности организации в области информационной безопасности.



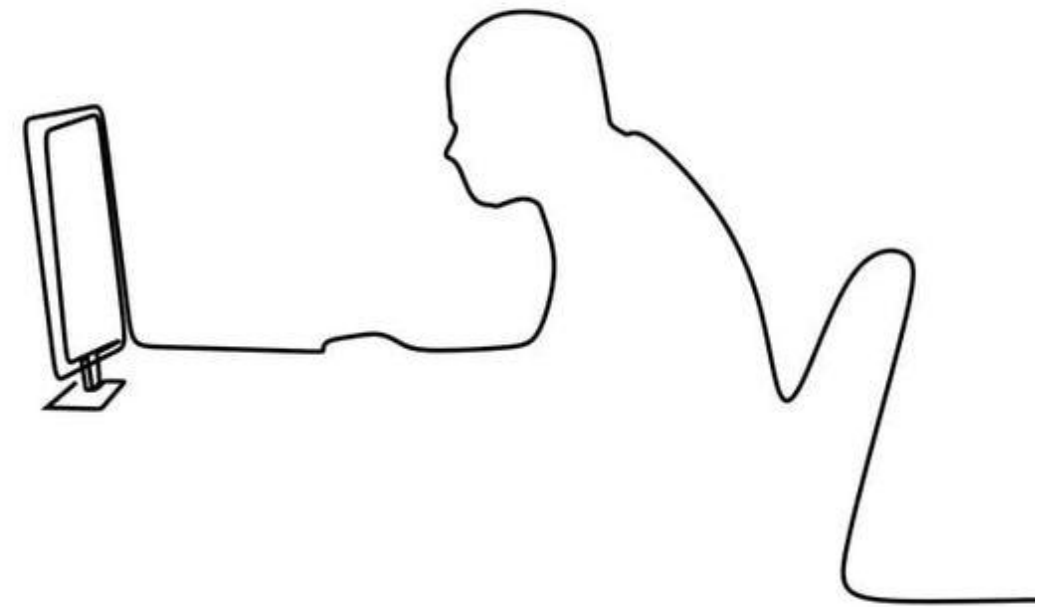
Цели и критерии оценки защищенности





Предпосылки к анализу и оценке защищенности

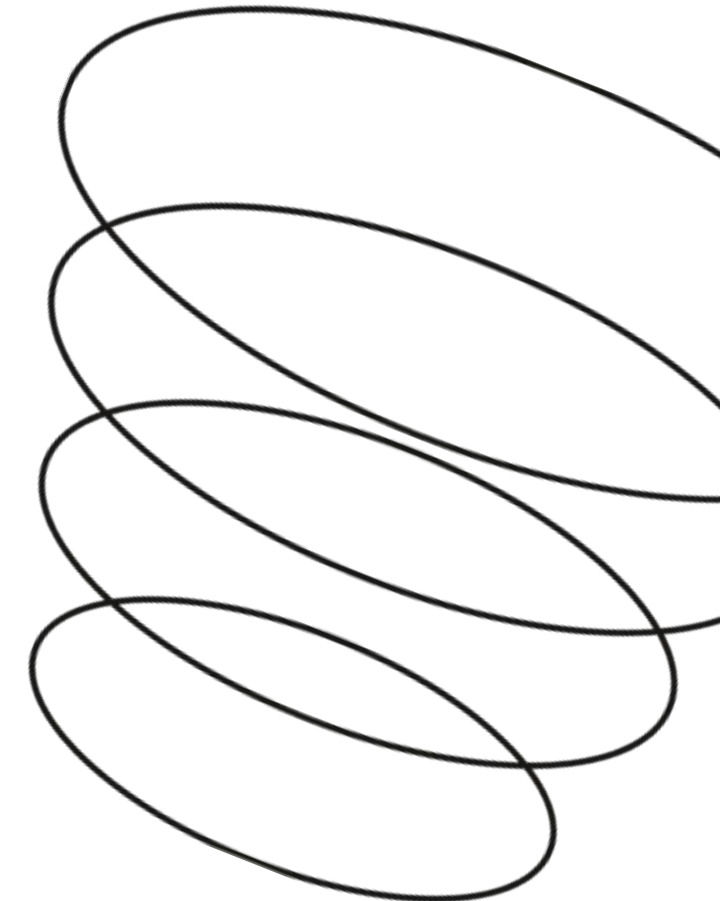
-  Требования нормативных правовых актов и нормативно-методических документов.
-  Требования локальных нормативных актов.
-  Потребности организации.





Цели оценки защищенности

- 📌 Официальное подтверждение выполнения требований к обеспечению ИБ:
 - аттестация объекта информатизации;
 - сертификация организации (деятельности);
 - получение допуска (лицензии) к определенной деятельности.
- 📌 Содействие в улучшении системы защиты информации:
 - составная часть контрольных мероприятий (PDCA);
 - идентификация областей потенциального улучшения.





Критерии оценки защищенности

-  Международные стандарты (ISO/IEC 27001, ISO 22301, PCI DSS и др.).
-  Национальные стандарты (ГОСТ Р ИСО/МЭК 27001, ГОСТ Р 57580.1 и др.).
-  Отраслевые стандарты (СТО БР ИББС 1.0, СТО Газпром и др.).
-  Требования нормативных правовых актов и нормативно-методических документов (приказ ФСТЭК России №№ 17, 21 и др.).
-  Требования и указания отраслевых регуляторов.
-  Требования локальных нормативных актов (политики, процедуры и др.).
-  Отдельные способы реализации угроз (сценарии кибератак).



Примеры критериев аудита

-  ... обеспечивают **учет объектов** информационной инфраструктуры, используемых для обработки, хранения и (или) передачи защищаемой информации, в том числе банкоматов и платежных терминалов.
-  **Регистрация нарушений** и сбоев в формировании и сборе данных о событиях защиты информации.
-  **Запрет на повтор** недавно используемых паролей (пароль не должен совпадать ни с одним из 24 предыдущих).
-  **Access** to program source code shall **be restricted**.
-  Domain controllers **have antivirus software** with routine execution of virus scans.
-  Cabling **rooms are locked** with limited access, and **access** to cabling rooms **is logged** and **managed**.
-  **Encryption** and **user authentication is required** for wireless networks. Use of tokens *is strongly recommended*.*

* Требования рекомендательного характера не могут выступать обязательными критериями



Критерии: Ключевые слова

Существительное

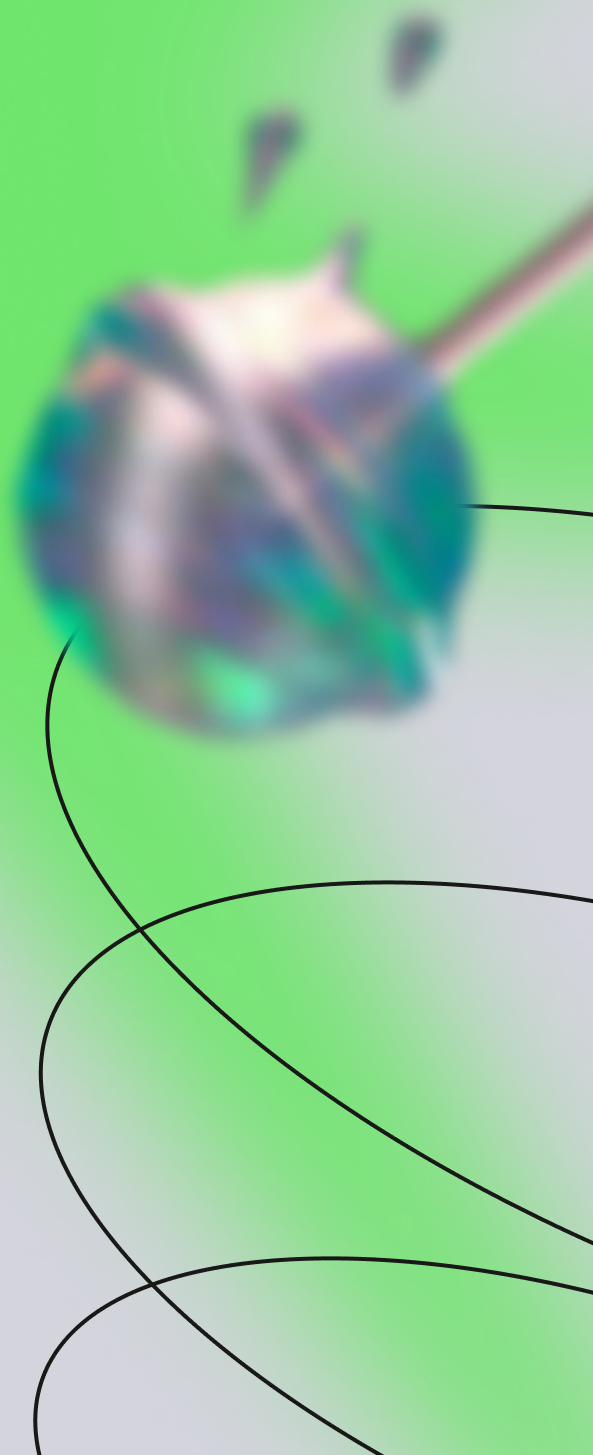
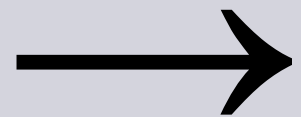
-  Запрет *чего-то/кому-то*.
-  Разрешение *чего-то/кому-то*.
-  Учет *чего-то/кого-то*.
-  Регистрация *чего-то/кого-то*.
-  Контроль *чего-то/кого-то*.
-  ...

Глагол

-  Запретить *что-то*.
-  Разрешить *что-то*.
-  Учесть *что-то*.
-  Регистрировать *что-то*.
-  Контролировать *что-то*.
-  ...
-  ~~Обеспечивать~~ существительное
-  ~~Позволять~~ существительное
-  ~~Создавать~~ условия для существительное



Варианты анализа и оценки защищенности

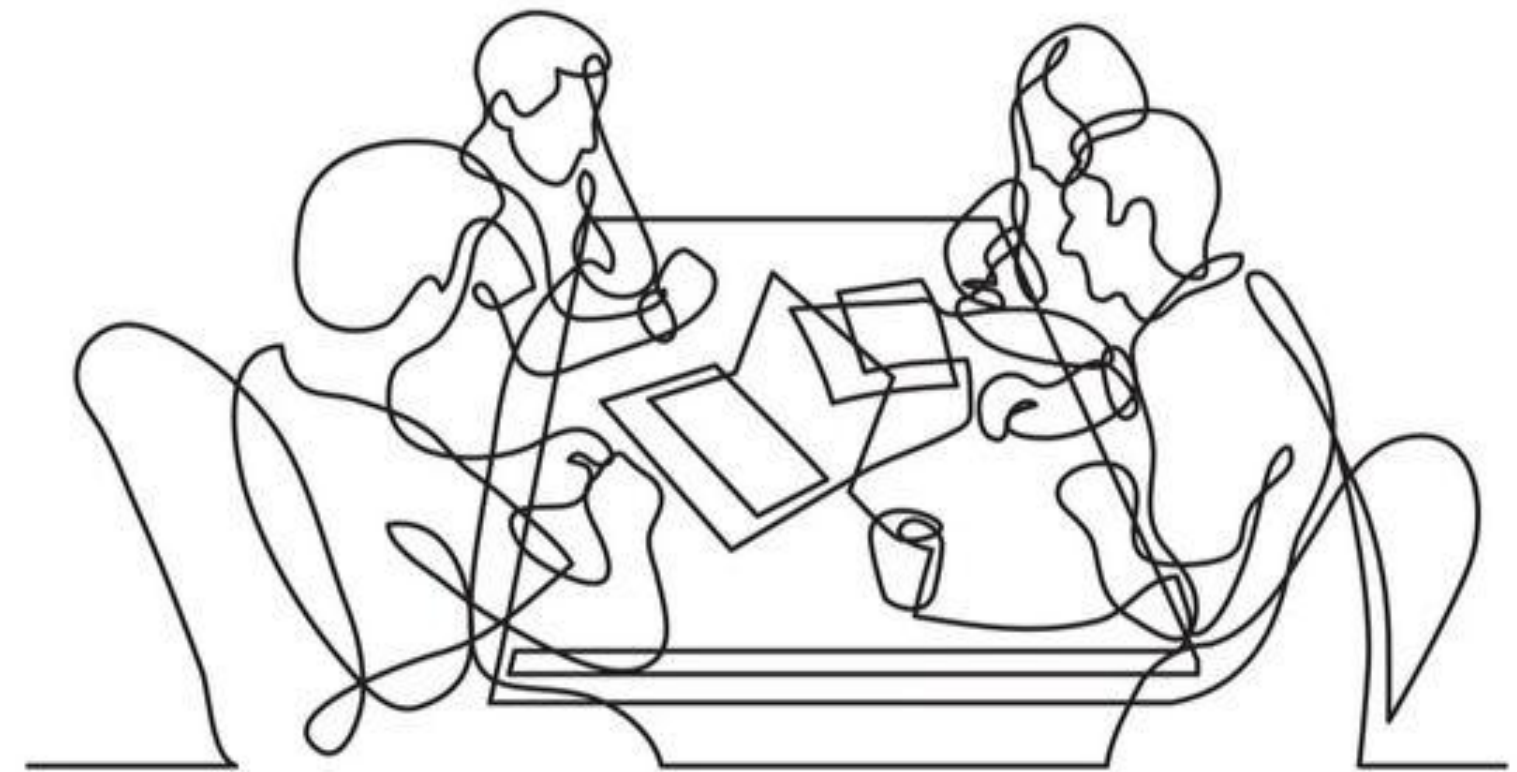




Проблематика оценки

Мы хотим оценить, соответствует ли *что-то* *чему-то*

- 📌 Как это сделать?
- 📌 А как делать это регулярно?
- 📌 А как делать это системно?



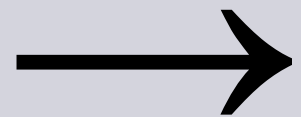


Варианты анализа и оценки защищенности

-  Аттестация объекта информатизации по требованиям защиты информации и периодический контроль уровня защиты информации.
-  Оценка эффективности реализованных в рамках системы защиты персональных данных мер по обеспечению безопасности персональных данных.
-  Аудит ИБ организации / системы.
-  Тестирование на проникновение.
-  Выявление известных уязвимостей.
-  Киберучения.
-  Анализ безопасности (уязвимостей) отдельных приложений.
-  Верификация.



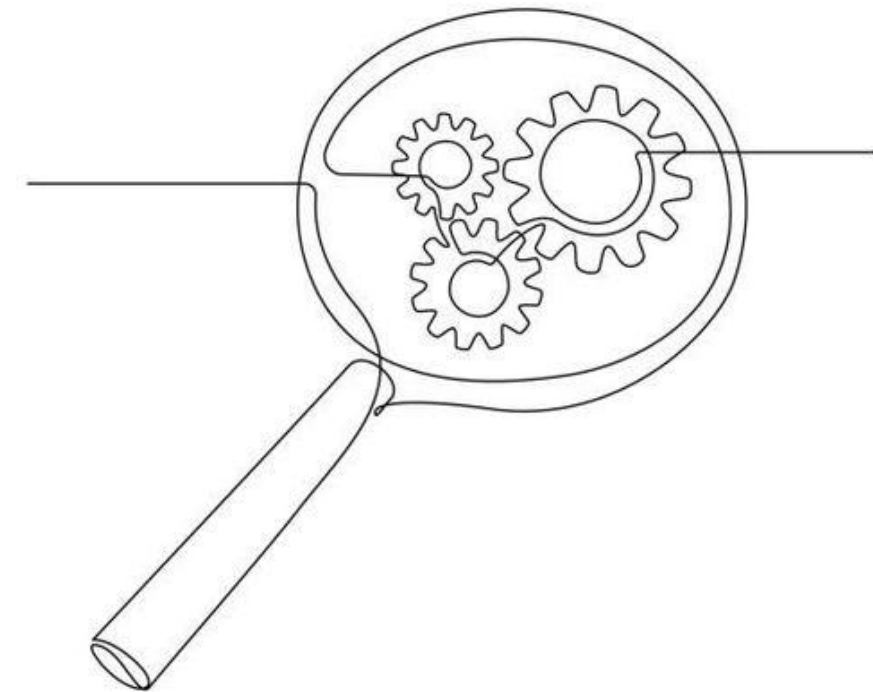
Виды аудита информационной безопасности





Виды аудита информационной безопасности

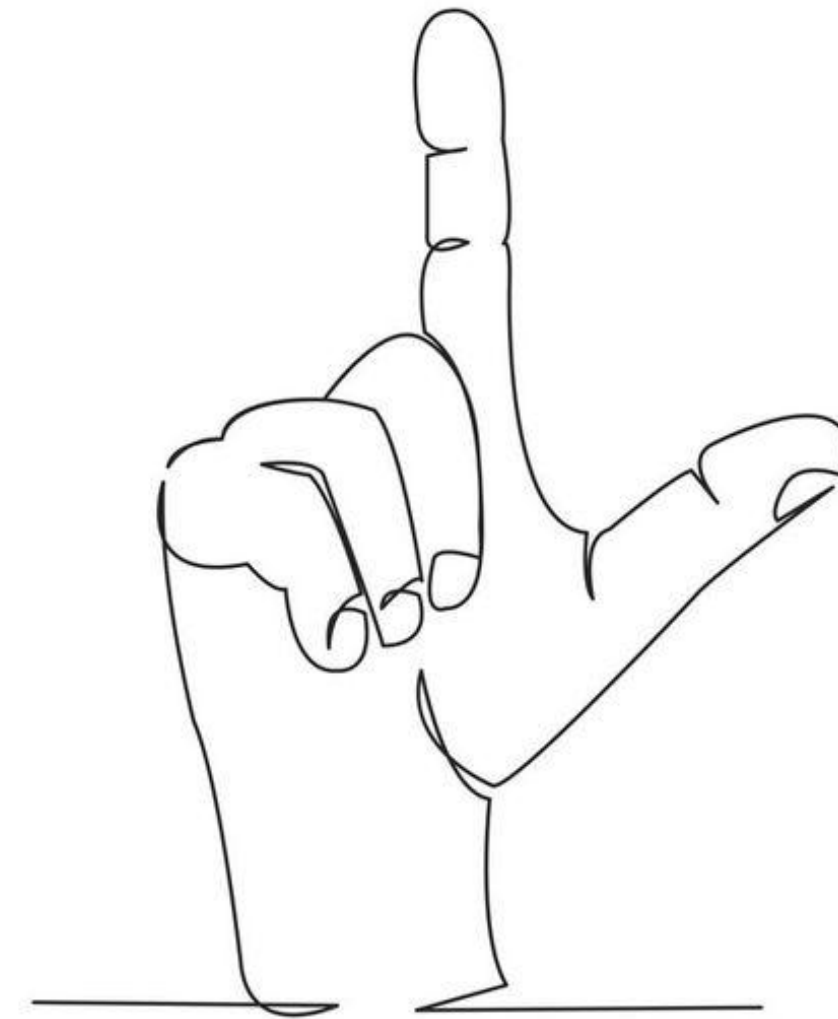
-  Внутренний аудит информационной безопасности:
 - аудит первой стороной.
-  Внешний аудит информационной безопасности:
 - аудит второй стороной (аудит поставщика);
 - аудит третьей стороной (сертификационный аудит).





Принципы проведения аудита информационной безопасности

-  Честность.
-  Беспристрастность .
-  Профессиональная осмотрительность.
-  Конфиденциальность.
-  Независимость.
-  Подход, основанный на свидетельстве.
-  Риск-ориентированный подход.





Область аудита (audit scope)



Организационная структура.



ИТ-инфраструктура (ИС и СрЗИ).



Виды деятельности и процессы.



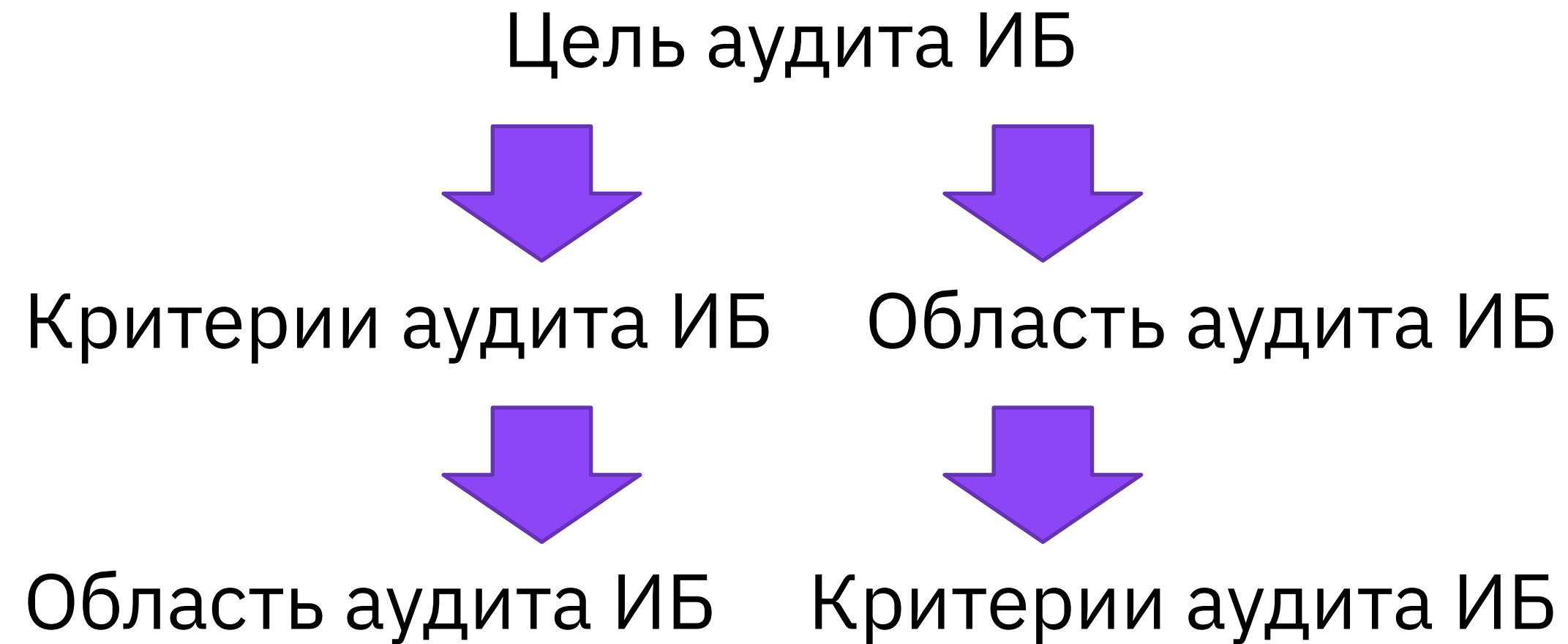
Местонахождение (локации).



Охватываемый период времени.



Взаимосвязь целей, критериев и области аудита





Фазы аудита информационной безопасности

-  Установление контакта с проверяемой организацией.
-  Определение возможности проведения аудита ИБ.
-  Подготовка к проведению аудита ИБ.
-  Непосредственное проведение аудита ИБ.
-  Подготовка и рассылка отчета по аудиту ИБ.
-  Завершение аудита ИБ*.
-  Выполнение последующих действий по результатам аудита ИБ*.

* Не являются обязательными фазами



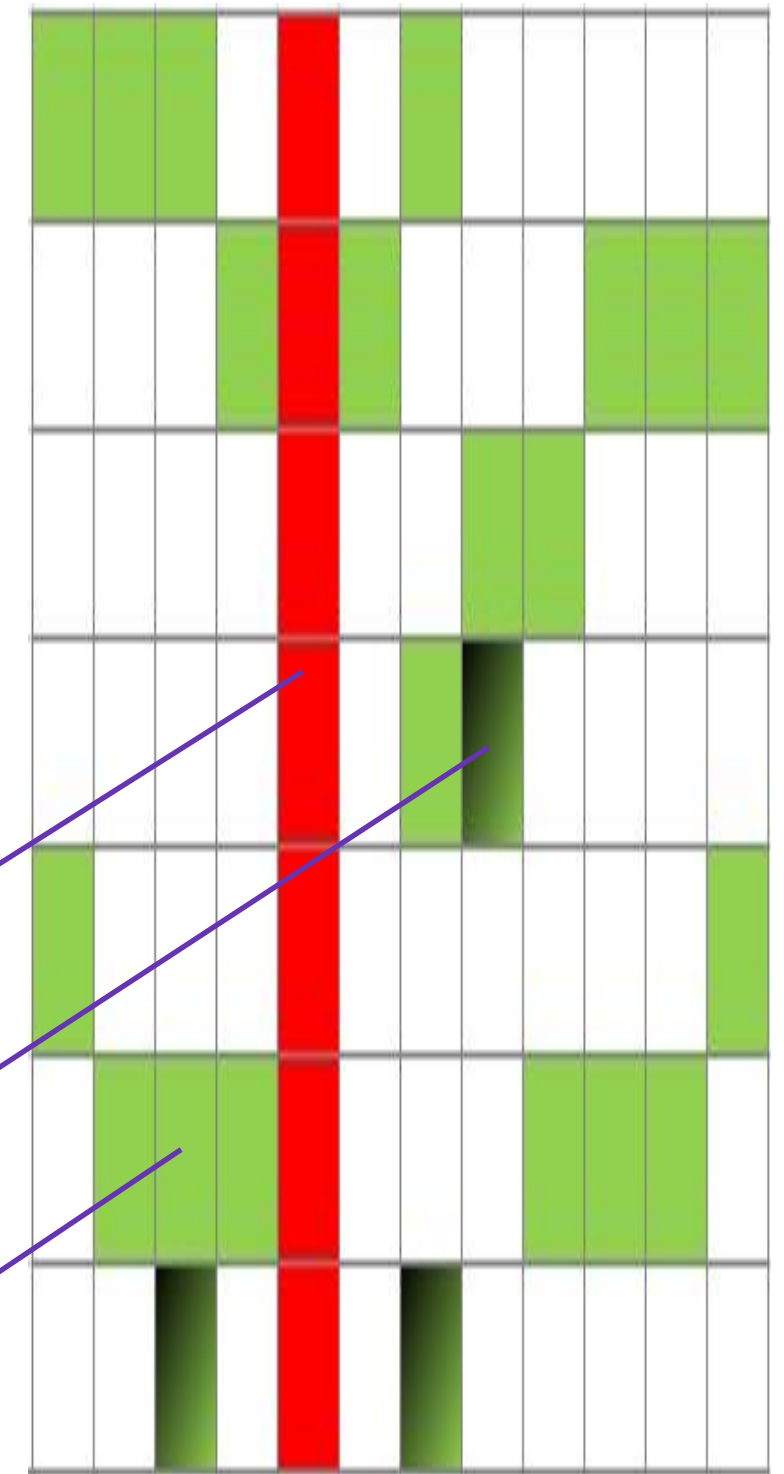
Объём мероприятий по аудиту информационной безопасности

-  **Горизонтальные проверки:** проверяются отдельные элементы из области аудита ИБ на соответствие отдельным критериям аудита ИБ.
-  **Вертикальные проверки:** проверяются отдельные элементы из области аудита ИБ на соответствие всем критериям аудита ИБ.
-  **Кросс-проверки:** проверяются отдельные элементы из области аудита ИБ. разными способами на соответствие одному и тому же критерию аудита ИБ.

Вертика-
льные
проверки

Кросс-
проверки

Горизон-
тальные
проверки





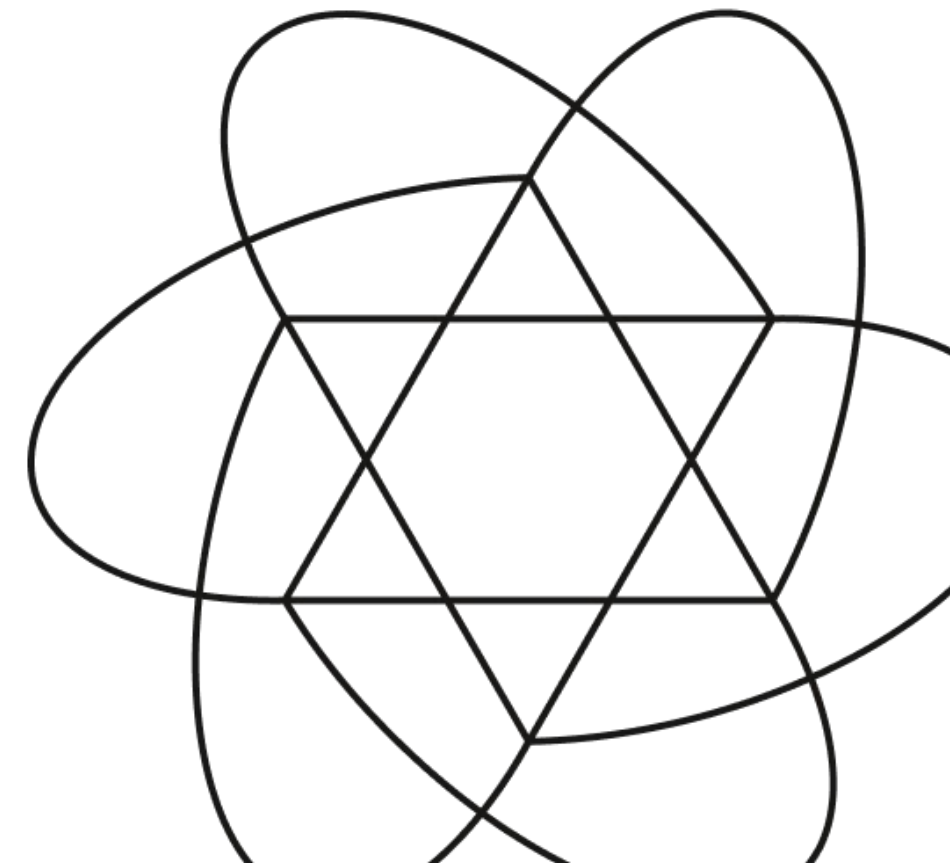
Выборка в рамках аудита информационной безопасности

- ✚ На основе суждения аудитора (исходя из опыта и компетенции)
- ✚ Случайный отбор (по таблице случайных чисел)
- ✚ Статистический или систематический отбор
- ✚ Комбинация вариантов отбора
- ✚ Авторские выборки (например: $\sqrt{n}$ от общего числа элементы из области аудита ИБ)



Методы аудита информационной безопасности

-  Проведение интервью.
-  Заполнение проверочных (опросных) листов и вопросников.
-  Проведение анализа документов.
-  Наблюдение за выполнением работы.
-  Получение данных от инструментальных средств.





Методы аудита информационной безопасности

	Местоположение аудитора	
	На территории	На расстоянии
С взаимодействием людей	Проведение интервью	Проведение интервью через интерактивные средства коммуникации
	Заполнение проверочных листов с участием персонала	Заполнение проверочных листов с использованием интерактивных средств коммуникации
	Проведение анализа документации с участием представителей	Проведение анализа документации с использованием интерактивных средств коммуникации
Без взаимодействия людей	Проведение анализа документации без участия персонала	Проведение анализа документации без использования интерактивных средств коммуникации, без участия персонала
	Наблюдение за выполнением работы без участия персонала. Наблюдение за выполнением работы с помощью технических средств	Наблюдение за выполнением работы с помощью технических средств, обеспечивающих надзор/контроль за производственной деятельностью
	Заполнение аудитором проверочных листов без участия персонала	Заполнение аудитором проверочных листов без участия персонала
	Получение данных от инструментальных средств	Получение данных от инструментальных средств, в т.ч. из общедоступных источников (сети Интернет)



Варианты оценок

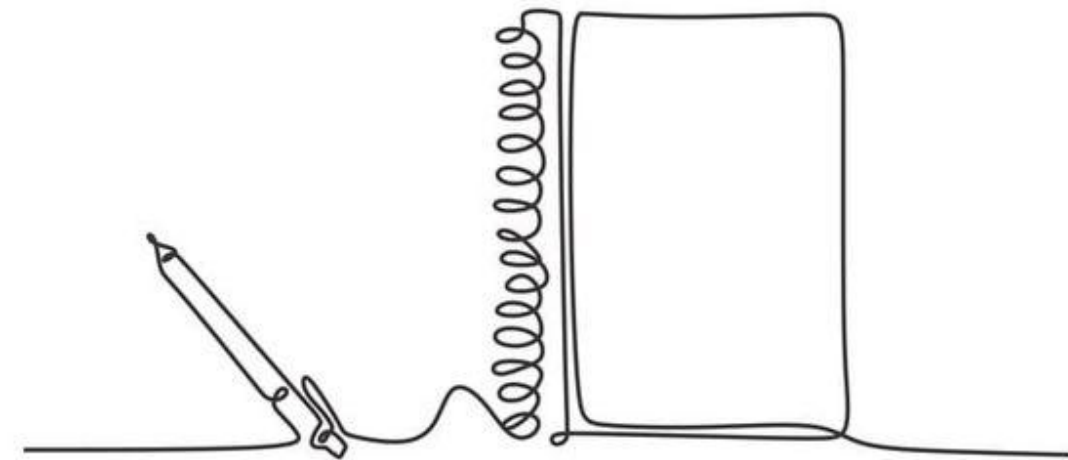
- 📌 Для отдельных критериев аудита ИБ:
 - «Бинарные» оценки (выполнено / не выполнено).
 - «Градиентные» оценки (выполнено / выполнено частично / не выполнено и т.п.).
- 📌 Для итоговых оценок – отсутствие/наличие замечаний:
 - Значительное (major nonconformity): полное или повторяющееся невыполнение установленных критериев аудита ИБ.
 - Незначительное (minor nonconformity): разовое невыполнение установленных критериев аудита ИБ (отклонение, упущение).
- 📌 Итоговый показатель (интегральная оценка).
- 📌 Соотнесение со шкалой оценок.





Заключение (audit conclusion)

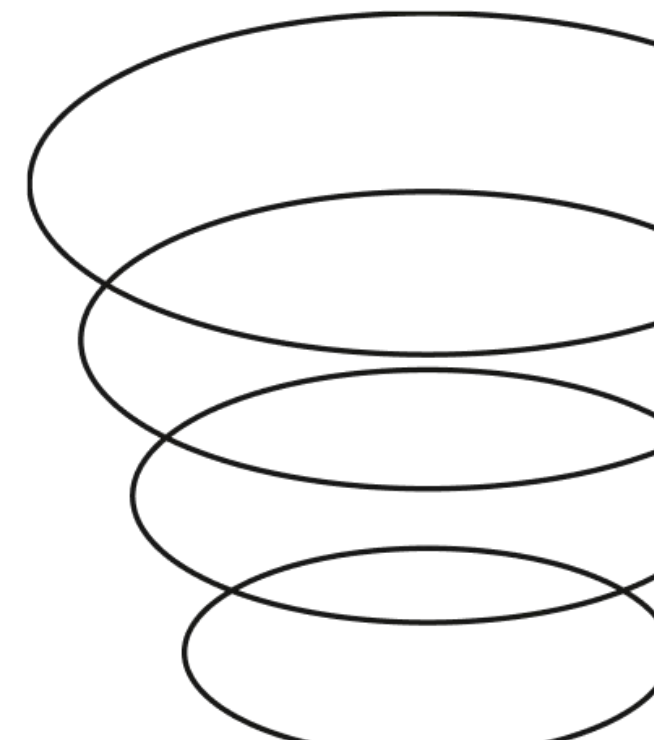
-  Безусловно положительное.
-  Условно положительное.
-  Отрицательное.
-  Отказ от выражения заключения.





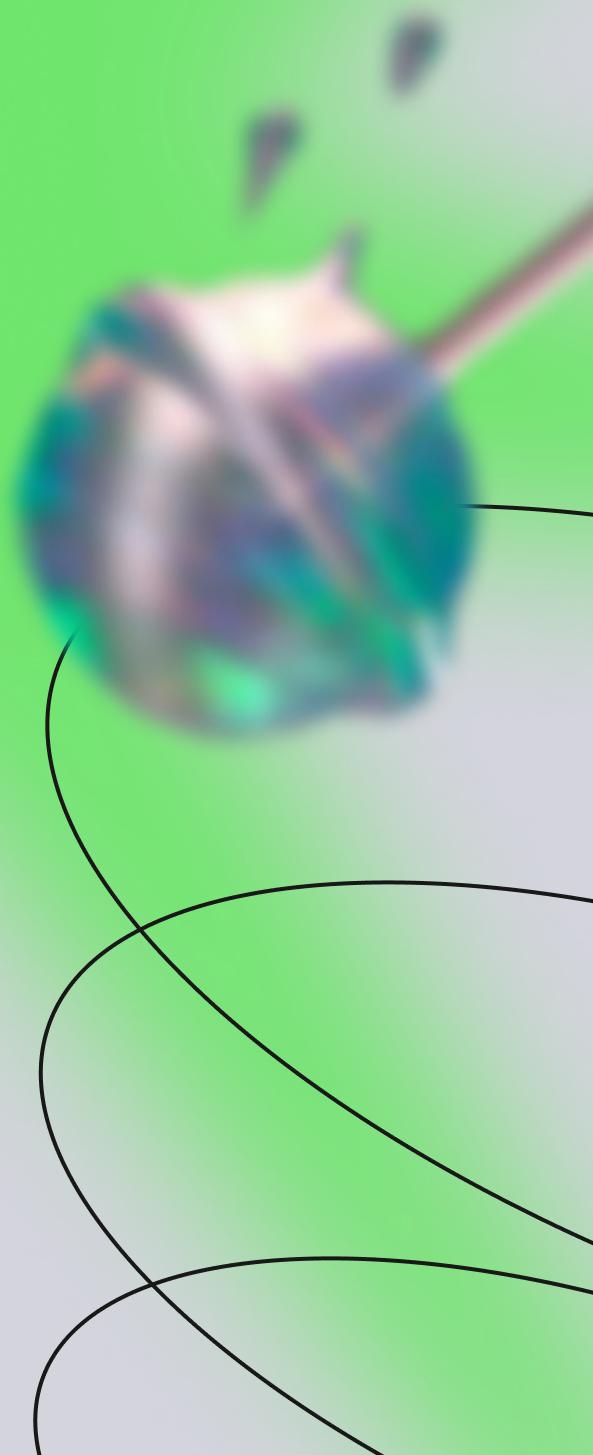
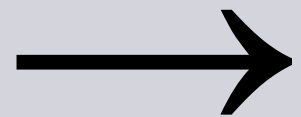
Выводы по модулю

-  Аудит – это универсальный инструмент оценки деятельности.
-  Аудит ИБ – это самый распространённый вариант анализа и оценки защищенности организаций.
-  Принципы проведения аудита, направлены на получение объективной и достоверной оценки.
-  Критерии аудита ИБ – это неотъемлемая часть аудита ИБ, без которой аудит ИБ невозможен.
-  Область аудита ИБ – это не только ИТ-инфраструктура (системы или СРЗИ).





Разведка по открытым источникам (OSINT)





**«90% разведданных приходит из открытых источников
и только 10% – за счёт работы агентуры».**

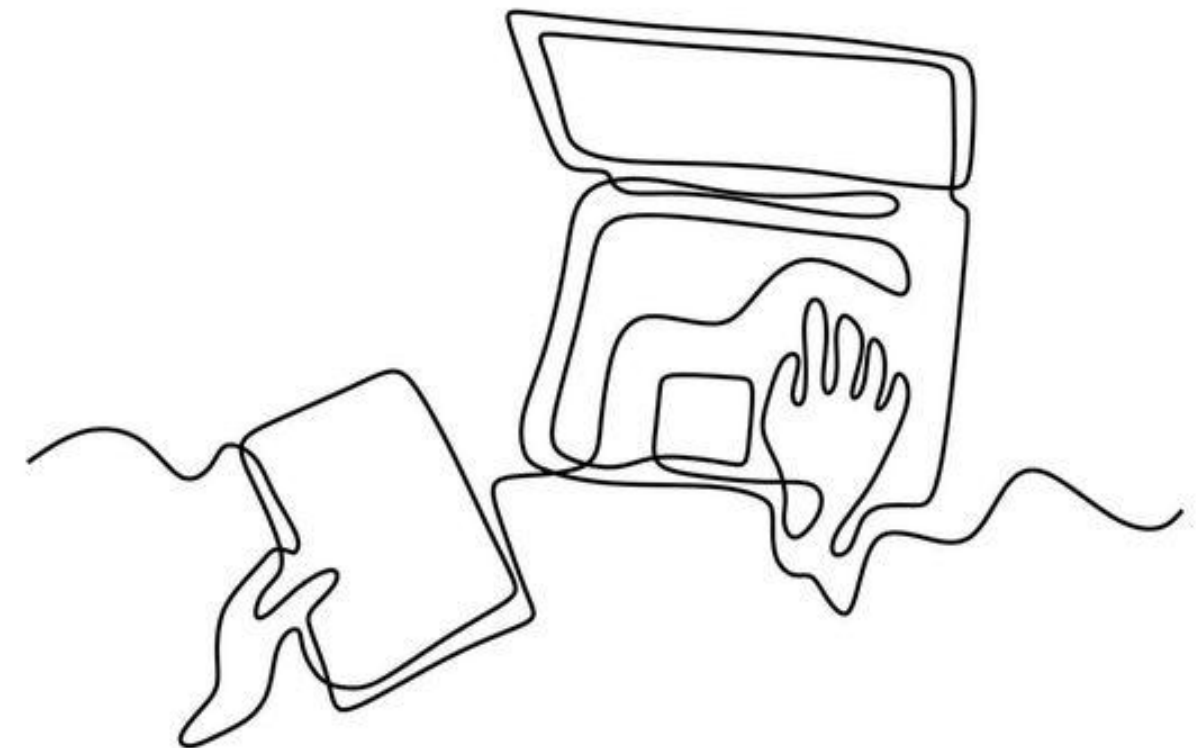
Руководитель РУМО США, генерал-лейтенант Самуэль Уилсон
1977 г.





Общедоступные источники

- 📌 Информация из СМИ и других печатных источников (телефонные справочники и т.д.).*
- 📌 Интервьюирование, телефонные звонки, «наведение справок».*
- 📌 Информационно-телекоммуникационные сети, включая сеть Интернет.



* Первоочередные общедоступные источники в недалёком прошлом



Отправные точки для OSINT

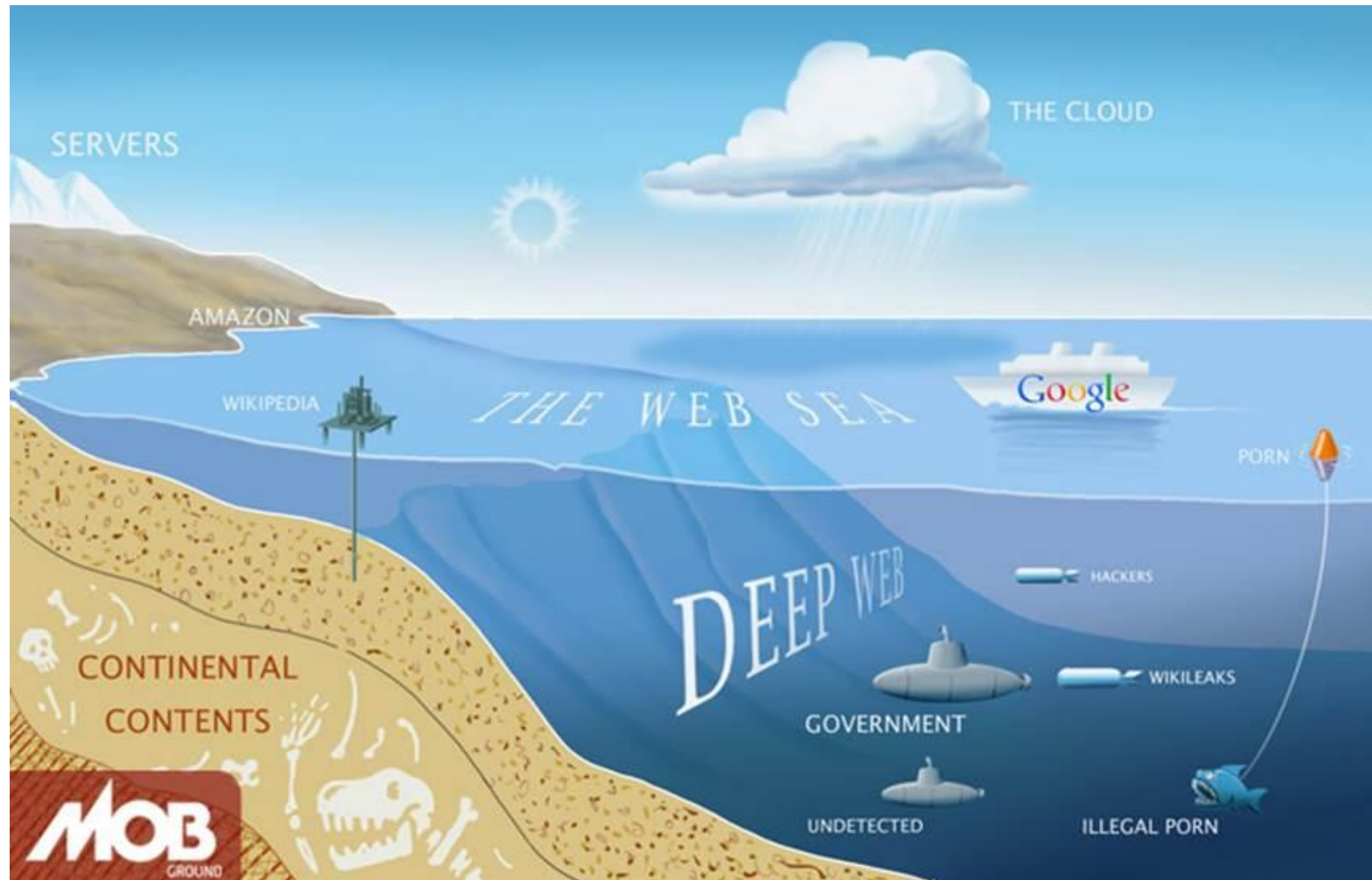
-  Наименование организации.
-  Имя человека/никнейм, логин в социальных сетях.
-  Адрес электронной почты, номер телефона.
-  Наименование/дата события (мероприятия).



Методы OSINT

-  **Активные:** прямое взаимодействие с объектом (например, просмотр корпоративного веб-сайта, сканирование сетевого периметра и т.п.).
-  **Пассивные:** отсутствие прямого взаимодействия с объектом (например, в поисковых системах Google/Yandex, анализ вакансий организации, анализ материалов мероприятий с участием объекта и т.п.) .

Пассивный метод OSINT – Google Hacking





Google Hacking

Operator Examples	
Operator Example	Finds Pages Containing
<i>sailboat chesapeake bay</i>	the words sailboat , Chesapeake and Bay
<i>sloop OR yawl</i>	either the word sloop or the word yawl
<i>"To each his own"</i>	the exact phrase to each his own
<i>virus -computer</i>	the word virus but NOT the word computer
<i>Star Wars Episode +III</i>	This movie title, including the roman numeral III
<i>~boat loan</i>	loan info for both the word boat and its synonyms: canoe , ferry , etc.
<i>define:sarcastic</i>	definitions of the word sarcastic from the Web
<i>mac * x</i>	the words Mac and X separated by exactly one word
<i>I'm Feeling Lucky (Google link)</i>	Takes you directly to first web page returned for your query

Search Parameters		
Search Parameters	Value	Description of Use in Google Search URLs
q	the search term	The search term
filter	0 or 1	If filter is set to 0, show potentially duplicate results.
as_epq	a search phrase	The value submitted is as an exact phrase. No need to surround with quotes.
as_ft	i = include e = exclude	The file type indicated by as_filetype is included or excluded in the search.
as_filetype	a file extension	The file type is included or excluded in the search indicated by as_ft .
as_occt	any = anywhere title = page title body = text of page url = in the page URL links = in links to the page	Find the search term in the specified location.
as_dt	i = include e = exclude	The site or domain indicated by as_sitesearch is included or excluded in the search.
as_sitesearch	site or domain	The file type is included or excluded in the search indicated by as_dt .
as_qdr	m3 = three months m6 = six months y = past year	Locate pages updated with in the specified time frame.



Google Hacking and Defense Cheat Sheet

POCKET REFERENCE GUIDE

SANS Stay Sharp Program

<http://www.sans.org>

<http://www.sans.org/staysharp>

Purpose

This document aims to be a quick reference outlining all Google operators, their meaning, and examples of their usage.

What to use this sheet for

Use this sheet as a handy reference that outlines the various Google searches that you can perform. It is meant to support you throughout the Google Hacking and Defense course and can be used as a quick reference guide and refresher on all Google advanced operators used in this course. The student could also use this sheet as guidance in building innovative operator combinations and new search techniques.

This sheet is split into these sections:

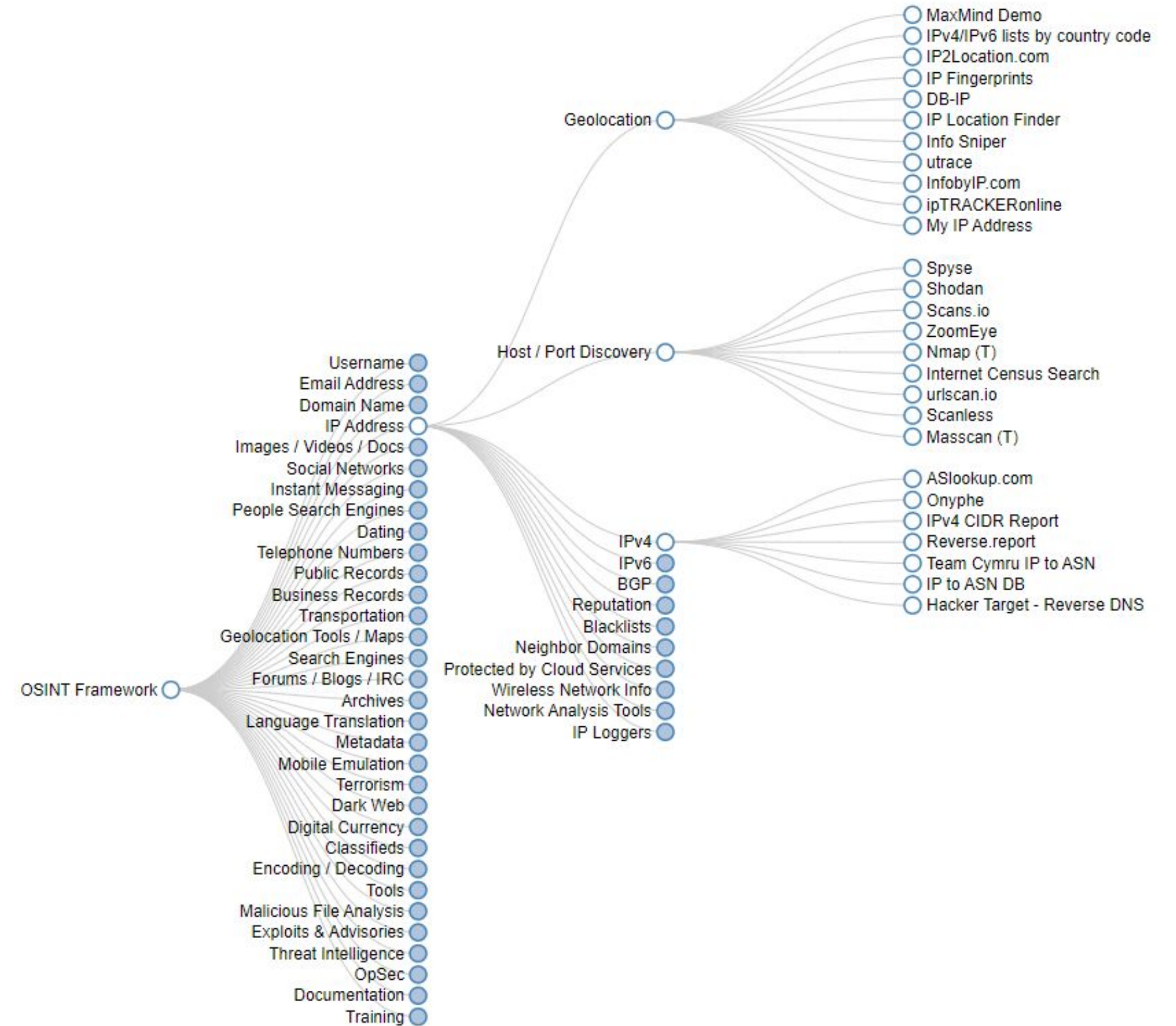
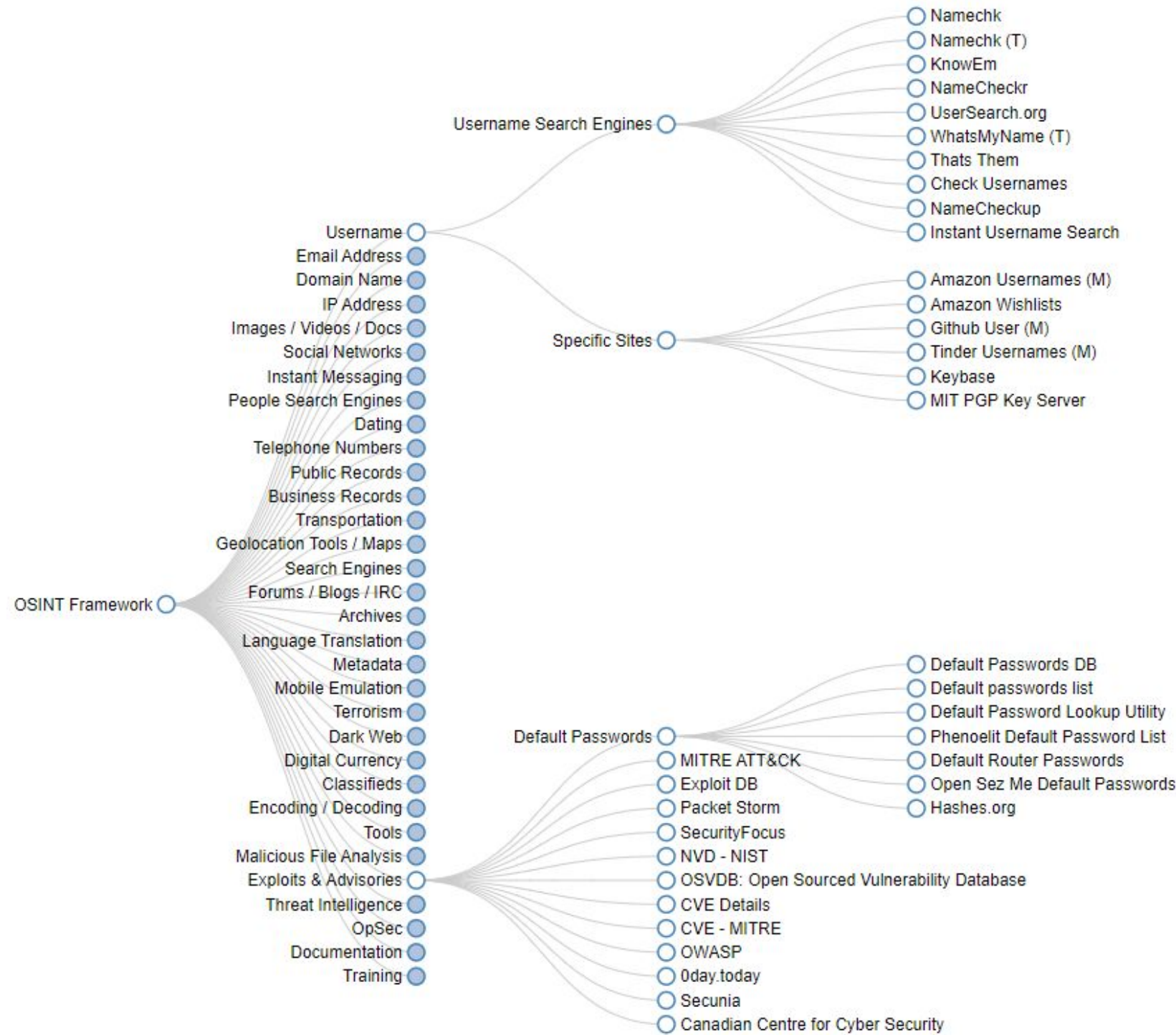
- Operator Examples
- Advanced Operators
- Number Searching
- Calculator Operators
- Search Parameters

References:

<http://www.google.com/intl/en/help/refinesearch.html>
<http://johnny.ihackstuff.com>
<http://www.google.com/intl/en/help/cheatsheet.html>



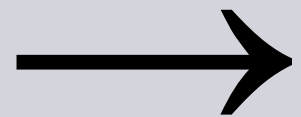
Методы и инструменты OSINT



* OSINT Framework: <https://osintframework.com/>



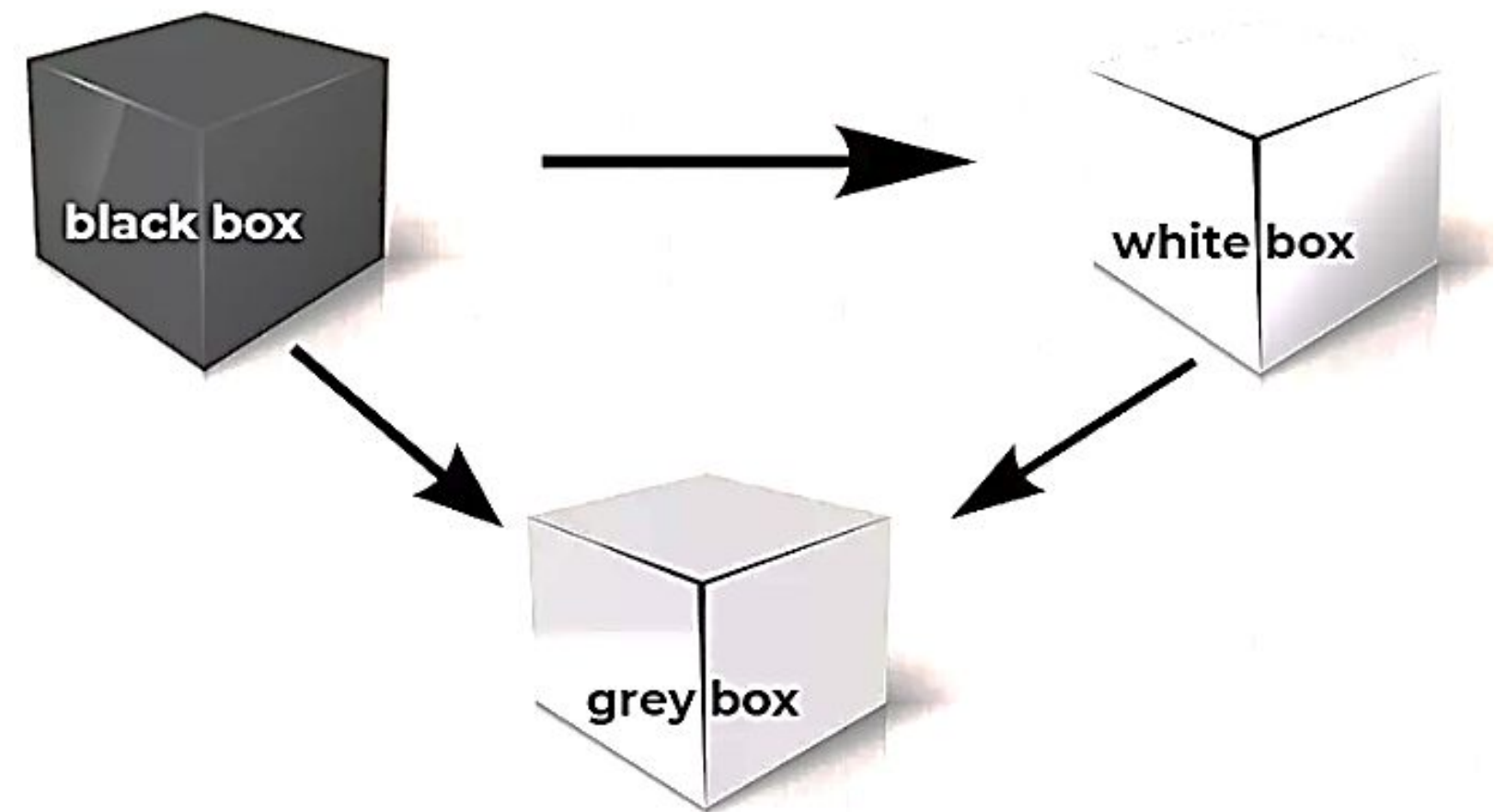
Тестирование на проникновение (pentest) и киберучения (cyber exercise)





Форматы тестирования на проникновение

- 📌 «Белый ящик» (black box).
- 📌 «Серый ящик» (gray box).
- 📌 «Чёрный ящик» (white box).





Направления тестирования на проникновения

-  Оценка защищенности сетевого периметра, сетевых устройств и протоколов.
-  Оценка защищенности беспроводных сетей.
-  Оценка защищенности веб-приложений.
-  Оценка защищенности операционных систем.
-  Оценка защищенности систем управления базами данных (СУБД).
-  Оценка защищенности средств виртуализации.
-  Оценка защищенности специализированных банковских приложений.
-  Оценка защищенности мобильных устройств.

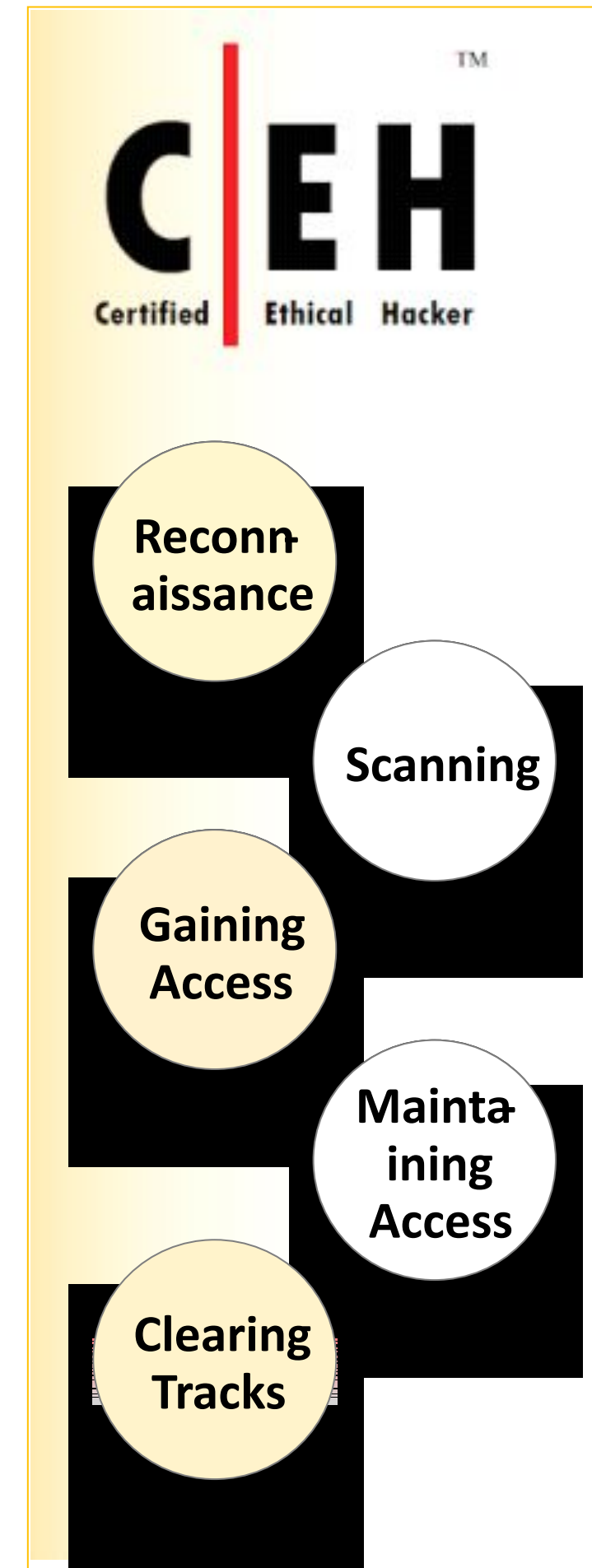


Фазы тестирования на проникновения

- 📌 Планирование тестирования.
- 📌 Разработка тестов.*
- 📌 Проведение тестирования.*
- 📌 Разработка отчетности по результатам тестирования.

* Базируется на моделях Cyber Kill Chain® и MITRE ATT&CK®

** Альтернативные фазы тестирования на проникновения от EC-Council





Достоинства и недостатки тестирования на проникновения

Достоинства:

-  Высокая достоверность.
-  Наглядность получаемых результатов.

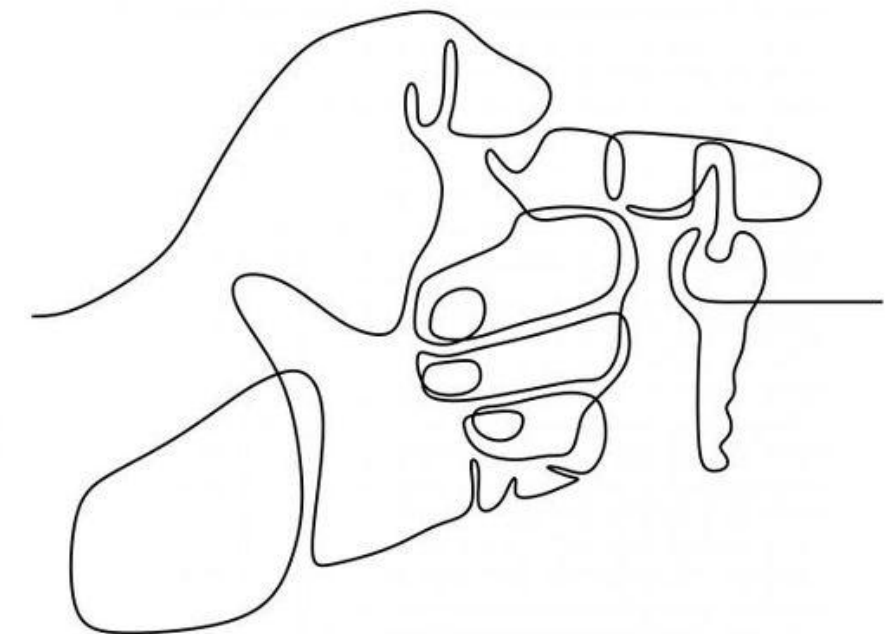
Недостатки:

-  Высокие требования к квалификации исполнителя (способность команды пентестеров воспроизводить только действия нарушителя, равного или уступающего по квалификации).
-  Низкая степень автоматизации.



Выявление известных уязвимостей*

-  Идентификация наименований и версий программного обеспечения и поиском в базах данных известных для них уязвимостей.
-  Запуск тест-программ (эксплойтов), воспроизводящих в полном объёме или частично выполнение кибератак с использованием известных уязвимостей.



* Как составная часть тестирования на проникновение или самостоятельное мероприятие



Достоинства и недостатки выявления известных уязвимостей

Достоинства:

-  Высокая достоверность сведений о выявленных уязвимостях при использовании формата «белого ящика».
-  Низкие требования к квалификации исполнителя.
-  Высокая степень автоматизации.
-  Воспроизводимость исследования.

Недостатки:

-  Низкая достоверность сведений о выявленных уязвимостях при использовании формата «чёрного ящика».
-  Возможность сбоев и отказов в функционировании программного обеспечения при проведении исследования с использованием формата «чёрного ящика».
-  Необходимость предоставления привилегированного доступа при использовании формата «белого ящика».



Цели и форматы киберучений

Цели киберучений:

-  получение оценки процессов реагирования на инцидент ИБ;
-  определение объективных и актуальных направлений совершенствования SOC-ов.

Штабные киберучения:

-  максимально комфортный (игровой) формат (low stress);
-  все участники знают, что это учения;
-  основная подготовка: организационная.

Практические киберучения:

-  максимально приближенный к реальности формат (high stress);
-  минимальное число участников знает, что это учения;
-  основная подготовка: техническая.



Фазы киберучений

-  Организационная и/или техническая подготовка к киберучениям.
-  Активная фаза киберучений, в т.ч. непрерывный контроль ситуации со стороны организаторов.
-  Действия после киберучений (lessons learned).





Достоинства и недостатки киберучений

Достоинства:

-  Высокая наглядность.
-  Оперативность реализации (дни – часы).

Недостатки:

-  Нахождение времени для участия в активной фазе киберучений ряда участников, в т.ч. ТОП-менеджмента.
-  Узкая направленность (отдельные способы реализации угроз (сценарии кибератак)).

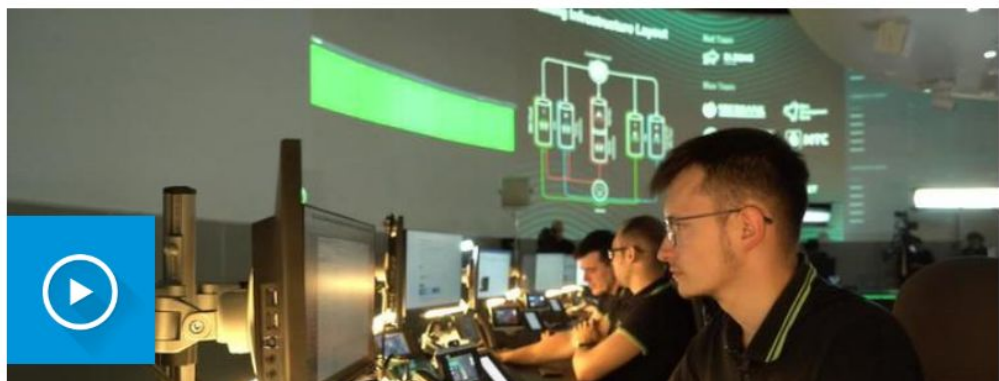


Популярность киберучений

ТМК и Группа Синара провели первые кросс-отраслевые корпоративные киберучения в промышленности на Национальном киберполигоне

19 июня 2019 19:54 | Алена Логвинова

Сбербанк провел масштабные киберучения



ЦБ запустит киберучения для банков в середине 2020 года

Татьяна Манаенко, 19 декабря 2019



Учения будут проходить в формате стресс-тестирования на устойчивость к киберугрозам один раз в два года, рассказал В. Поздышев.

В ЦБ подвели итоги киберучений, проведенных в этом году

ЦБ в этом году провел два больших цикла киберучений среди кредитных организаций



Ростелеком-Солар провел киберучения совместно с ЦФТ

Татьяна Манаенко, 21 января 2020



Проект был направлен на проверку систем мониторинга и отработку про отражения атак, тактик, техник и процедур реагирования команды кибер

Positive Technologies проводит публичные киберучения на собственной инфраструктуре

Дата публикации 18 октября 2022

Киберучения на «живой» инфраструктуре с публичным представлением результатов, тактик и техник атакующих, кейсов реагирования SOC¹ проходят впервые в России и мире

На ПМЭФ впервые в России прошли международные киберучения

июня, 2022

РТК-Солар ПМЭФ киберполигон киберучения хакерские атаки

19 СЕНТЯБРЯ 2019

В Банке «Санкт-Петербург» прошли штабные киберучения

Руководители и специалисты Банка «Санкт-Петербург» под руководством экспертов НТЦ «Вулкан» отработали навыки действий при выявлении и локализации учебного киберинцидента. За несколько часов напряженной работы был разыгран сценарий условной атаки со стороны злоумышленников, потребовавший слаженной и эффективной работы нескольких подразделений Банка. Киберучения позволили на практике закрепить положения регламентов и процедур и дали хорошую основу для дальнейшего совершенствования внутрибанковских процессов обеспечения информационной безопасности.

Команда организаторов учений заслужила высокую оценку Заказчика, о чем свидетельствует полученное «Вулканом» благодарственное письмо.



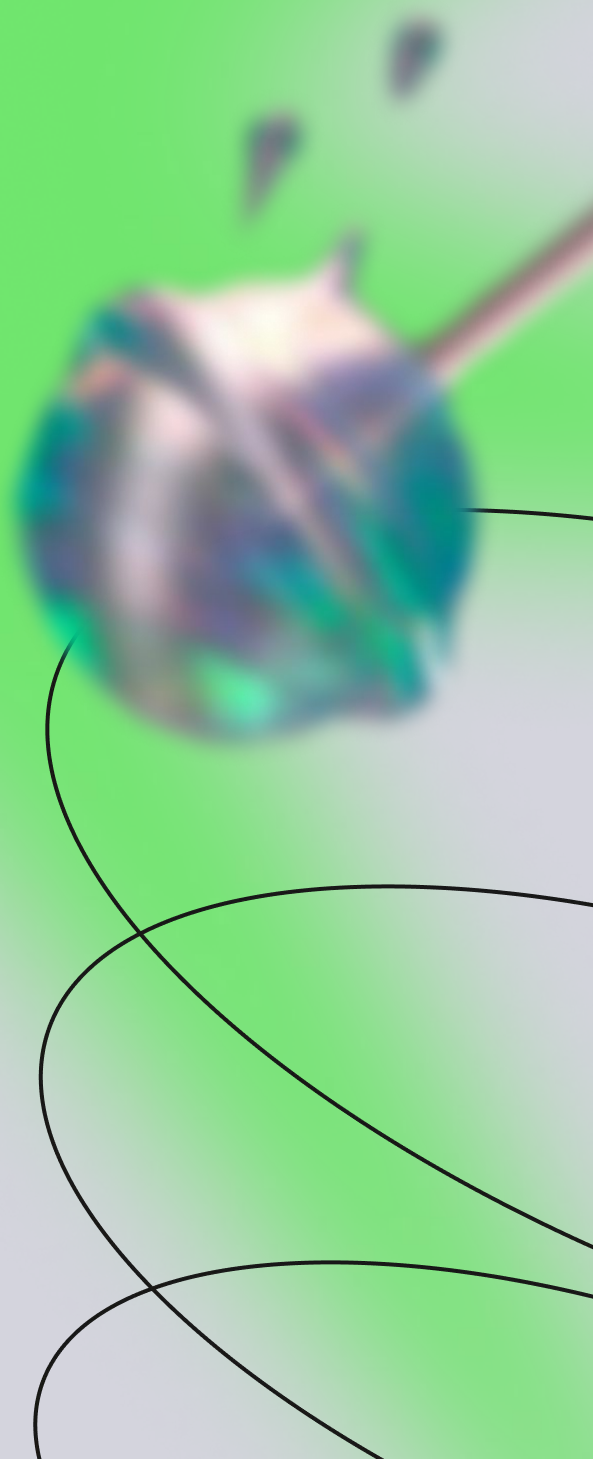
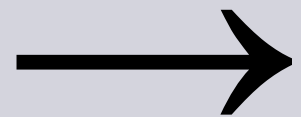
Выводы по модулю

-  Существует несколько вариантов практически ориентированных вариантов анализа и оценки защищенности – понимайте их достоинства и недостатки.
-  Используйте наиболее удобный Вам вариант анализа и оценки защищенности.
-  В анализе и оценке защищенности важна регулярность.





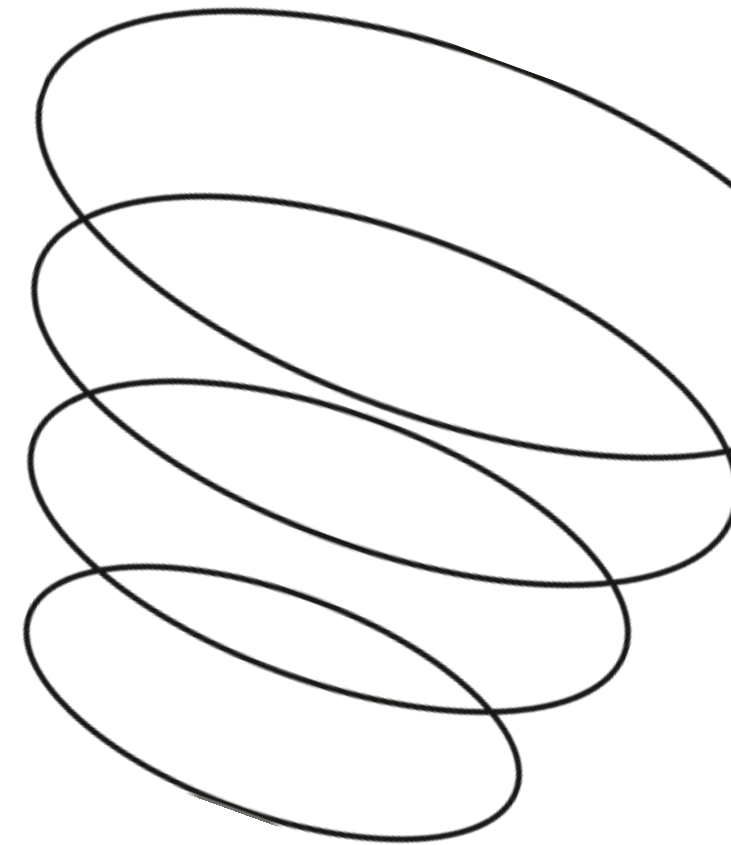
Методы анализа защищенности отдельных приложений





Методы анализа защищенности отдельных приложений

- 📌 Анализ (инспекция) кода (code review).
- 📌 Статический анализ (static application security testing (SAST)).
- 📌 Динамический анализ (dynamic application security testing (DAST)).
- 📌 Компонентный анализ (software composition analysis (SCA)).
- 📌 Анализ внешних зависимостей (open source analysis (OSA)).
- 📌 Фаззинг-тестирование ПО (fuzz testing).





Анализ (инспекция) кода (code review)

-  Оценка соответствия разработанного кода требованиям, предъявляемым к структурированию и оформлению кода, именованию объектов, разделению на модули, использованию специальных средств обеспечения качества кода, предусмотренных используемыми языками программирования и средствами разработки.
-  Оценка полноты и качества документирования кода, включая документирование заголовков программных модулей, прототипов функций и структур данных, комментарии к выполнению существенных операций.
-  Оценка соответствия алгоритмов, реализованных в исходном коде, программной документации, в т.ч. выявление явных не декларированных возможностей (программных закладок), ошибок программного кода, попыток запутывания (обфускации) программного кода и использования иных приемов, затрудняющих проведение контроля.



Двойное чтение
кода



Статический анализ (SAST)

1. Реализуется без реального запуска исследуемого приложения.
2. Статический анализ направлен на идентификацию потенциально опасных фрагментов кода, включая:
 -  вызовов функций, методов, процедур (далее – функции) с передачей им в качестве аргументов данных, вводимых пользователем или принимаемых из внешних источников;
 -  текстов функций преобразования форматов данных;
 -  вызовов системных функций и функций обеспечения ИБ, в т.ч. функций обеспечения ИБ операционной системы и специализированных технических защитных мер, функций ввода/вывода, управления памятью и системными ресурсами;
 -  текстов функций, осуществляющих проверку прав доступа и принятие решений, основанных на значениях атрибутов безопасности;
 -  текстов функций, самостоятельно реализующих функциональность обеспечения ИБ, в т.ч. криптографические функции, аутентификацию пользователей и проверку прав доступа, генерацию данных мониторинга ИБ;
 -  текстов функций, предусматривающих установление соединения с внешними компонентами, с передачей им аутентификационных данных;
 -  текстов обработчиков ошибок и исключений.



Динамический анализ (DAST)

1. Реализуется с выполнением приложения на определенной совокупности наборов тестовых исходных данных.
2. Динамический анализ направлен на идентификацию потенциально опасных вариантов исполнения кода, включая:
 -  исследование особенностей исполнения потенциально опасных функций при задании заведомо некорректных аргументов;
 -  построение динамических путей исполнения программы и идентификацию точек принятия решений, существенных для выполнения функций обеспечения ИБ;
 -  поиск чувствительной информации в оперативной памяти и в аргументах функций;
 -  исследование особенностей исполнения программы при типовых атаках (переполнение буфера, внедрение SQL-операторов в данные, используемые для формирования запросов к СУБД).



Компонентный анализ и анализ внешних зависимостей (SCA/OSA)

1. Анализ кода отдельных приложений или совокупности приложений в произвольной форме (репозиторий, директория с файлами, Docker-образ, бинарник и т.п.).
2. Компонентный анализ направлен на идентификацию потенциально опасных (несовместимых) компонентов, включая:
 -  выявление лицензионного состава open source и коммерческих компонентов, оценку совместимости лицензий самого приложения и компонентов между собой (лицензионная чистота);
 -  выявление прямых зависимостей (тех, которые явно указываются разработчиком) и транзитивных зависимостей, анализ цепочек вызовов зависимостей;
 -  выявление известных уязвимостей для компонентов по базам уязвимостей (например, National Vulnerability Database, Github Advisory и др.).



Фаззинг-тестирование (fuzz testing)

1. Реализуется с выполнением приложения на определенной совокупности наборов тестовых исходных данных, которые изначально являются неправильными, не ожидаемыми приложением и/или случайными.
2. Фаззинг-тестирование направлено на идентификацию потенциально опасных вариантов исполнения кода, включая:
 -  переполнение буфера;
 -  выход за границы массива;
 -  ошибки сегментации;
 -  отказ в обслуживании;
 -  бесконечный цикл или бесконечная рекурсия;
 -  большое потребление ресурсов памяти и/или процессора;
 -  «состояние гонки»;
 -  деление на 0.



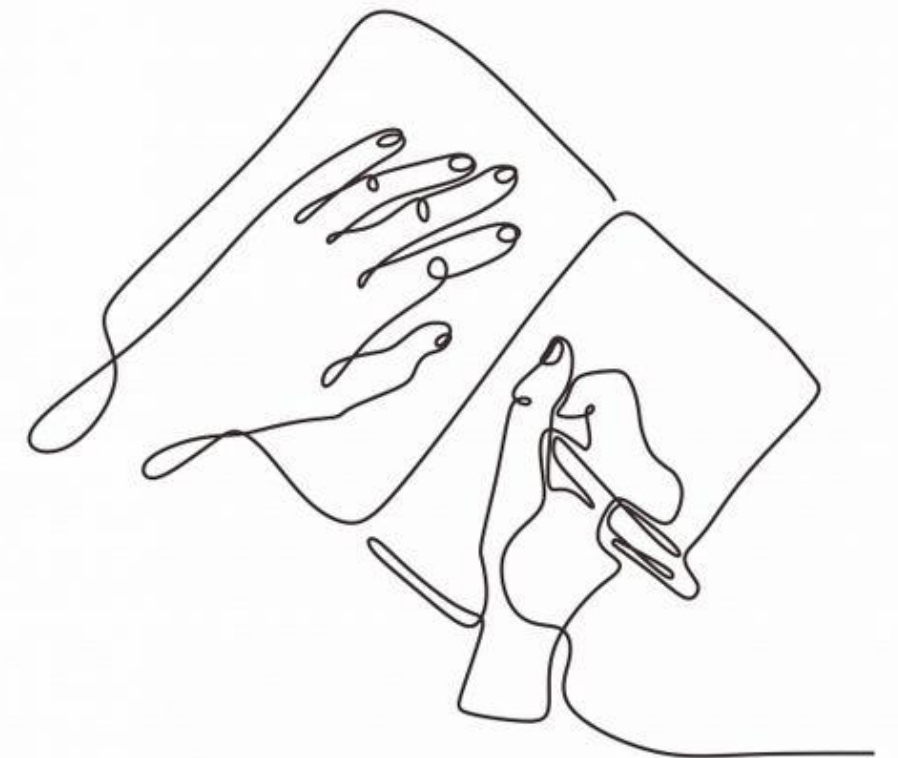
Выводы по модулю

-  Существует несколько вариантов анализа защищенности отдельных приложений, на практике их комбинируют и учитывают в цикле CI/CD.
-  Большинство вариантов требуют применения специализированных автоматизированных средств (программных инструментов), которые должны учитывать используемые Вами языки разработки и среды разработки и сборки.
-  В анализе и оценке защищенности отдельных приложений важна непрерывность с учетом SDLC.



Выводы по уроку

- 📌 Анализ и оценка защищенности являются неотъемлемой частью обеспечения ИБ, но при этом являются отдельным направлением (специализацией) в области обеспечения ИБ.
- 📌 Существуют различные варианты анализа и оценки защищенности, имеющие свои «драйверы» и области применения.
- 📌 Зачастую мероприятия по анализу и оценке защищенности требуют привлечения независимых профессиональных специалистов («сторонний взгляд»).
- 📌 Результаты анализа и оценки защищенности должны служить входными данными для пересмотра и совершенствования систем обеспечения ИБ.





Спасибо за внимание

